
Cyberboswachters

De beste digitale stropers zijn ook de beste cyberboswachters

Dams Tim



Inhoudsopgave

Introductie	1
Wordt het erger?	3
Het voorbije decenium	3
Voor 2010	3
2010: En dan verscheen Stuxnet	4
2013 : Onze privacy te grabbel gegooit	5
2014: hoe veilig is <i>the cloud</i> ?	6
Ook in 2014: wie zijn de daders?	8
2015: Stuxnet bewaarheid	9
2015: Scheidingen en zelfmoord	9
2016: Internet-of-horrors	10
2017: Ransomware wordt gemeengoed	11
En nu: de geopolitiek macht van sociale media en grote datalekken	12
En de toekomst?	13
Het is erger, maar...	13
GDPR en privacy	15
Cryptografie	17
Waarom cryptografie?	17
CIA en het security model	17
Encryptie	18
Kerckhoffs principe	20
De eerste algoritmes	21
Substitutie: Caesar encryptie	21
Transpositie: scytale encryptie	22
Combinatie	23
Cryptanalyse	25
Symmetrische encryptie	25
Sleuteloverdracht	26

Block en Stream cipers	26
Streamciphers	26
Blockciphers	32
Asymmetrische encryptie	32
Social Engineering	33
Network security	35
IPS en IDS	35
Honeypots	35
Dos	35
Wifi Security	35
Internet security	37

Introductie

Dit is versie 0.0.2 (2/3/21)

Nu dat Zie Scherp en Zie Scherper ingeblikt zijn, wordt het tijd voor een nieuw project. De teksten in deze PDF zijn pre-alpha. Dit wil concreet zeggen dat:

- De teksten nog niet zijn nagelezen qua inhoud én spelling.
- De teksten nog niet compleet zijn.
- Veel afbeeldingen nog niet gecleared zijn om gebruikt te worden qua rechten.

Alle feedback is in deze fase zéér welkom:

- Schrijffouten.
- Zinnen die onduidelijk zijn.
- Paragrafen die je niet begrijpt.
- Zaken die ZEKER niet meer aangepast mogen worden omdat ze geniaal zijn.

Wordt het erger?

De laatste 10 jaar is de (cyber)security wereld erg veranderd. Ze doet dit niet omdat ze daar zin in heeft, maar wel als antwoord op wat er gebeurt in de wereld in zake cyberaanvallen, geopolitieke situaties, etc. Het is altijd een kat en muisspel, waarbij de boswachters helaas by definition steeds zullen achterlopen op de stropers. De kwaadwillige hackers hoeven maar 1 klein gaatje te vinden in je peperdure beveiliging en ze zijn binnen. Terwijl jij wel aan alles moet (proberen te denken). Dat het erger wordt is eigenlijk daarom bijna automatisch een evidentie. De wereld van de beveiliging gebeurt bij opbod en hoe beter de boswachters het bos kunnen verdedigen, hoe complexer de technieken zullen worden die de stropers hanteren.

Het voorbije decenium

We gaan geregeld terug in de tijd gaan om te bekijken hoe bepaalde verdedigings- en aanvalstechnieken zijn ontstaan, maar in dit hoofdstuk gaan we enkel terug tot 2010. Het jaar waarin Mack Zuckerberg, CEO van Facebook, door Time Magazine tot persoon van het jaar werd uitgeroepen en ook waarin Apple de eerste iPad tabletaan het publiek toonde. Het was helaas ook het jaar waarin het boorplatform, Deepwater Horizon, voor één van de ergste milieurampen ooit zorgde, alsook het jaar dat 33 mijnwerkers anderhalve maand lang 700 meter diep opgesloten zaten in een mijn. Voor ons was echter de meest cruciale gebeurtenis het ontdekken van **Stuxnet**.

Voor 2010

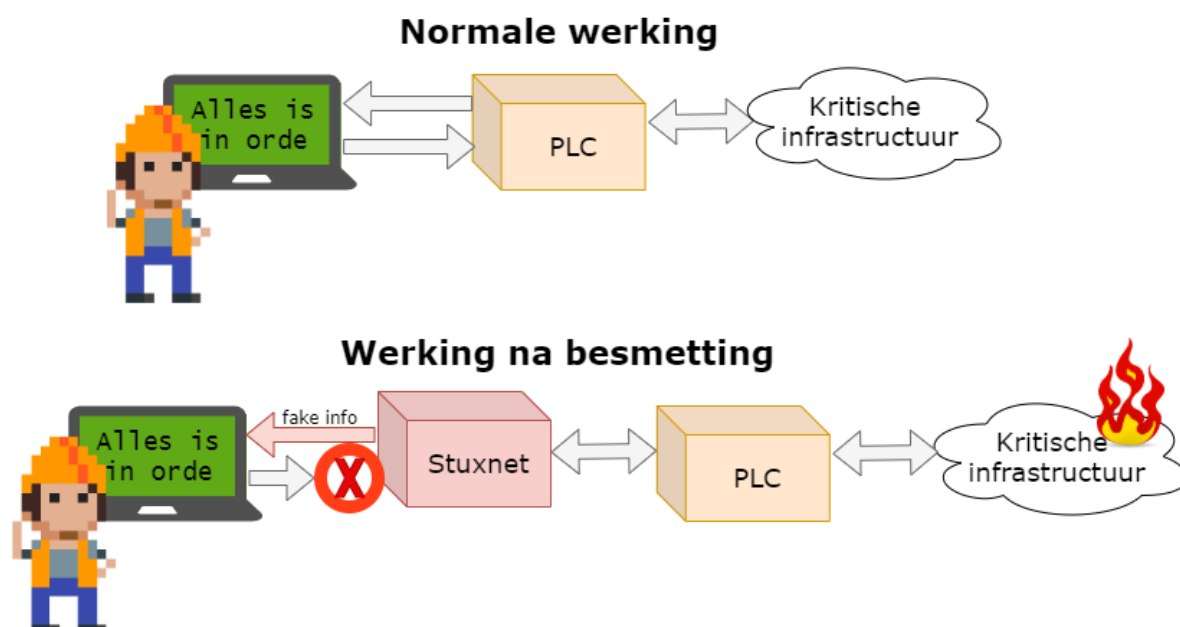
Voor het ontdekken van Stuxnet in 2010 leek de cyberbeveiligingswereld wel een wereld van (relatieve) peis en vree. Het ergste dat kon gebeuren was dat je computer een virusje opdeed waardoor je mogelijk wat data, en vooral veel werkuren, kwijt raakte. Virussen, wormen en spam waren alomtegenwoordig maar eigenlijk niet meer dan luizen in de pels van de eindgebruikers. Tuurlijk, er werd een grondig gevloekt als een virus je foto's verwijderde of wanneer een worm zichzelf verspreidde naar je contacten - denk maar aan het *ILOVEYOU* virus dat als een soort *social engineer* mensen deed geloven dat ze een potentiële liefdesmatch hadden waarop ze vol spanning de bijlage openden en zo de worm *in huis haalden*. Of wat te denken van de *Conficker* worm die in 2008 meer dan 3 miljoen systemen kon

besmetten en telkens de update-services van het Windows toestel uitschakelde. Tuurlijk, dat was irritant, maar menig mens zou maar al te graag terug naar die tijd willen gaan als daarmee ransomware, botnets en door overheden gesponsorde cyberaanvallen onbestaande zouden zijn.

2010: En dan verscheen Stuxnet

Virussen konden computers (tijdelijk) onbruikbaar maken. OK, lastig, maar niet het einde van de wereld. De Stuxnet worm die in 2010 plots op de radar verscheen kon dat potentieel wel, de wereld eindigen. Het was een worm die op maat was gemaakt om zogenaamde PLC systemen te controleren. Héél veel van onze kritische systemen zijn geautomatiseerd met behulp van zogenaamde *Programmable Logic Computers*, krachtige apparaten die machines kunnen aansturen zoals liften, robotarmen aan assemblagelijnen, zuiveringsinstallaties en zelfs kernreactors. PLCs vormen de interface tussen machines (hardware) en de computers (met software op) die de operatoren gebruiken om deze machines opdrachten te geven. Operators kunnen op hun systemen de machines bedienen en ten allen tijde controleren of deze naar behoren werken. Wat Stuxnet deed was zich tussen de hardware en de software nestelen. Als een virus besmette het laptops en computers en zocht het of er PLC-bedieningssoftware aanwezig was op het toestel. Als dat het geval was dan plaatste het zichzelf er tussen in zodat het:

1. de machines opdrachten kon geven zonder dat de operator dit wist.
2. aan de operator kon vertellen dat alles in orde was, terwijl in realiteit de PLC mogelijk desastreuze opdrachten aan de hardware gaf.



Figuur 0.1: Werking stuxnet

We moeten er geen tekeningetje bij maken wat de effecten kunnen zijn indien een Stuxnet variant bewust werd ingezet om bijvoorbeeld de machinerie in een kerncentrale of waterdam te saboteren. Zonder in details van Stuxnet in te gaan - daarvoor verwijzen we graag naar de uitstekende in 2006 verschenen documentaire “Zero Days” door Alex Gibney die een zeer ontluisterend én boeiend beeld over de zoektocht naar de oorsprong van het Stuxnet virus- is het duidelijk dat het verschijnen van dit virus een ommekeer betekende in wat de gevolgen van cyberterrorisme konden betekenen: mensenlevens stonden plots op het spel, niet enkel onze dierbare e-mails en digitale vakantiefoto’s.



Stuxnet bleek een bewust ontworpen virus te zijn dat probeerde een specifiek soort centrifuge te saboteren. Namelijk de centrifuges die onder andere Iran gebruikt om uranium te verrijken. De inlichtingendiensten van de Verenigde Staten en Israël zouden klaarblijkelijk Stuxnet hebben ontworpen om zo dit uraniumverrijkkingsproces van Iran te dwarsbomen.

2013 : Onze privacy te grabbel gegooid

Surfen op het internet was altijd een risico. We wisten dat onze datapakketjes over tientallen apparaten doorheen het internet wordt getransporteerd om zo tot bij hun doel te geraken. Cookies volgden al geregeld onze stappen en ook de recommendations van Amazon waren soms akelig accuraat. Dat was de prijs die we moesten betalen om de ontelbare bronnen van het internet te kunnen gebruiken. En als je echt wat meer privacy nodig had, dan schakelde je de “incognito” modus in van je browser. Maar ook dan was je je ervan bewust dat zelfs je ISP (*internet service provider*) en je doel konden meekijken. Hoe erg kan dat zijn?

Die gedachte leefde bij veel mensen tot dan. Internet was een nuttige tool en je wist dat er kon meegekeken worden door *derden* als ze dat echt wilden. Maar zou dit nu echt consequent en op grote schaal gebeuren? Neen toch.

Dat glazen huisje werd in 2013 hardhandig aan diggelen geslagen door twee belangrijke personen:

- Edward Snowden: als systeembeheerder bij de NSA, de Amerikaanse inlichtingendienst gericht op elektronische spionage, had hij toegang tot het doen en laten van de dienst. Snowden lekte een grote hoeveelheid documenten naar de bevolking die onder andere het *PRISM*-programma uit de doeken deed. Hieruit bleek dat de NSA complexe samenwerking heeft met enkele grote Amerikaanse internetbedrijven die zogenaamde *taps* op hun systemen hebben staan zodat de NSA “kan meeluisteren” op de netwerken.
- Julian Assange: rond 2013 waren er geregeld zogenaamde klokkenluiders (*whistleblowers*) die om persoonlijke overtuigingen vonden dat bepaalde informatie met het publiek moesten worden gedeeld. Zeker in dictatoriale middens kan dit levensgevaarlijk zijn. Julian Assange besepte dit

en richtte daarom in 2006 Wikileaks op. Een site waar klokkenluiders op een anonieme manier documenten konden *lekkeren*. Tot 2010 zijn zo enkele erg controversiële documenten met de wereld gedeeld die soms verregaande diplomatieke of geopolitieke gevolgen had.



Het is niet evident om over mensen als Assange en Snowden te praten zonder in een controversiële modderpoel te geraken. Voor de één is Snowden een held, voor de ander een verrader. In dit boek trachten we een objectief beeld te geven, zonder waardeoordelen te geven. Wat wel buiten kijf staat is dat zowel Snowden als Assange de wereld getoond hebben dat er in de duistere wandelgangen van de veiligheidsdiensten zaken gebeuren waar “normale stervelingen” zelden weet van hebben.

Het waren uiteraard vooral de onthullingen van Snowden die bij velen de oogkleppen deed afvallen. Op het Internet ben je hoegenaamd *niét* anoniem. Grote (en kleine) mogendheden en privéfirma's kunnen ons doen en laten op het internet bekijken en bewaren. Privacy en het internet zijn een oxymoron - een contradictorische term zoals zwarte sneeuw). Wanneer je je op het internet begeeft, op welke manier ook, gooi je een deel van je privacy te grabbel. En dat is iets dat helaas de voorbije 10 jaar er niet op verbeterd is.



Een interessant debat dat altijd opduikt bij deze problematiek is de “Ik heb toch niets te verbergen”-houding. In het kleine maar fijne boekje “Je hebt *wél* iets te verbergen” van onderzoeksjournalisten Maurits Martijn en Dimitri Tokmetzis (ISBN 9789082821611) wordt onherroepelijk brandhout gemaakt met deze stelling. Finaal zijn we volledig afhankelijk van de diensten die we gebruiken wat ze met onze data nu én belangrijker, in de toekomst zullen doen. Privé-informatie over jou die nu ogenschijnlijk ongevaarlijk lijkt, kan dat potentieel in de toekomst wel zijn wanneer onze normen, waarden of wetten veranderen.

2014: hoe veilig is *the cloud* ?

In 2014 vond er een controversie plaats die vooral de puberende tiener zich zal herinneren: *the fapping*. Deze naam laat weinig aan de verbeelding over en dekt helaas de lading goed. In het jaar dat Oekraïne Russische legers zag binnenrollen om de Krim (terug) in te palmen, verschenen er duizenden privéfoto's van een honderdtal *celebrities* op het internet. Deze privéfoto's hadden kwaadwillige hackers van de iCloud accounts van de slachtoffers gestolen en vervolgens gepubliceerd via Reddit, 4chan, etc. De foto's verspreidden zich als een lopend vuurtje en de slachtoffers konden enkel toezien hoe hun in de privésfeer opgenomen beelden door miljoenen mensen werden gedownload.

De beroemdheden hadden hun foto's in de cloud-opslag van Apple bewaard, iApple, zoals op dat moment duizenden gebruikers ook al deden. Deze dienst zorgt ervoor dat je je als eindgebruiker van eender waar aan je foto's kan, daar ze "in the cloud" staan, wat door de spectaculaire groei van de smartphones (en iPhones in dit geval) een populair concept was geworden. Ook diensten zoals Dropbox, Onedrive (toen nog SkyDrive) toonden aan dat er een grote vraag was naar online opslag van informatie.

Om dergelijke diensten te gebruiken dien je natuurlijk een veilig paswoord te hebben, daar eender wie, van eender waar, kan proberen zich een weg naar je data te verkrijgen door jouw paswoord te raden. In 2014 waren concepten zoals 2-factor-authentication (2FA) en biometrische beveiliging (meer daarover later) nog niet zo populair en dus was je geheime paswoord je enige bescherming tegen onrechtmatige toegang tot je data.

De diefstal van de foto's werd echter vergemakkelijkt om 2 redenen: * Sommige slachtoffers gebruikten makkelijk te raden, of snel te bruteforcen paswoorden. * Andere hadden de beveiligingsvragen ter goeder trouw ingediend. Veel diensten stellen een extra beveiligingsvraag (zoals "Wat is de naam van je eerste huisdier" of "Op welke school zat je vader") die ze kunnen gebruiken om jouw identiteit te verifiëren indien je je paswoord vergeten bent en je dit wenst te resetten. Wanneer jij of ik dit soort vragen invullen dan is dit 90% van de tijd informatie die nergens te vinden valt, enkel in de grijze massa in je hoofd en misschien in een gênant dagboekje uit je jeugd. Bij de Amerikaanse beroemdheden wiens iCloud werd gehackt, is dat niet zo. Hun leven kan volledig gereconstrueerd worden aan de hand van de ontelbare interviews die ze al hebben gegeven. Gegarandeerd dat ooit een interviewer al heeft gevraagd wat de kleur van zijn of haar eerste auto was, of in welk dorp hij of zij is opgegroeid.



Het is een verkeerde reflex om in dit soort zaken ogenblikkelijk aan *victim shaming* te doen (kijk maar naar het recentere voorval waarbij enkele Bekende Vlamingen het slachtoffer waren van catfishing). Ieder doet en laat wat hij wenst in z'n privésfeer - daarom heet het ook privé- maar het is belangrijk te beseffen dat als je zaken *in the cloud* bewaard, de kans erg bestaande is dat iets of iemand er ooit onrechtmatige toegang tot zal krijgen. U weze gewaarschuwd.



Niemand verplicht je om op de beveiligingsvragen een eerlijk antwoord te geven. Er bestaat geen leugendetector in die systemen of een mama die op je vingers komt tikken. Lieg er dus op los, maar onthoudt uiteraard je antwoord. Dankzij die beveiligingsvragen hou je echter een stok achter de hand moest je je paswoord vergeten zijn.

Ook in 2014: wie zijn de daders?

Het was te verwachten dat ook op cyberniveau er een wapenwedloop zou starten zoals, helaas, ook in de echte wereld plaatsvindt. Daar waar landen voorheen nog vooral defensieve cybermogelijkheden hadden, begon halverwege het vorige decennium dit arsenaal meer en meer uitgebreid te worden met offensieve cyberwapens. Het was met andere woorden wachten tot de eerste cyberaanvallen door soevereine staten op andere staten. Het probleem met dergelijke aanvallen is dat het als aangevallen mogendheid ongelooflijk moeilijk is om 1. De bron van de aanval te identificeren. Wie weet lijkt de aanval te komen vanuit land X, terwijl het eigenlijk land Y is dat gewoon de aanval via land X routeert. En het laatste dat je natuurlijk wil doen is het verkeerde land beschuldigen. 2. En wat als een hacker, zonder staatsinmengingen, beslist om op eigen houtje een cyberaanval te initiëren. Is het land van herkomst van die aanval dan verantwoordelijk voor de schade? 3. De “schade” van een cyberaanval is niet altijd duidelijk. Wanneer een raket op een stad wordt afgestuurd is dat een duidelijk *act of aggression* en is er grote kans op een militair conflict (indien de diplomatieke weg geen soelaas brengt). Maar is een cyberaanval, zoals een denial-of-service (DoS, zie later), genoeg reden om de oorlog buiten het cyberdomein te escaleren? Zijn er eigenlijk *rules of engagement*? Is er een conventie van Genève? Neen op dit alles. Daar cyberaanvallen zo moeilijk te traceren en identificeren zijn, blijft het allemaal het betere nattevingerwerk werk.

Een bewuste cyberaanval op een soevereine staat was al een enkele keer gebeurt (denk maar aan de cyberaanvallen in 2007 van Rusland op Estland) maar in 2014 was er helaas een nieuwe primeur. Ook nu moeten we naar Hollywood keren, niet om de beroemdheden en hun privé-kiekjes, maar omwille van een film waar een andere staat niet om kon lachen. In 2014 zou Sony een nieuwe film uitbrengen, getiteld “The Interview”, met James Franco en Seth Rogan. In deze komedie worden 2 journalisten gevraagd om tijdens hun interview van een Noord-Koreaanse hem te doden. De vergelijkingen met de Noord-Koreaanse leider Kim Jong-un waren voor iedereen duidelijk. Dat Noord-Korea op de tenen zou zijn getrapt stond dan ook in de sterren geschreven.

De daaropvolgende gebeurtenissen zijn nog steeds niet uitgeklaard, maar vast staat wel dat een selecte groep hackers toegang had gekregen tot confidentiële data op de servers van Sony en deze vervolgens op het internet lekte. De financiële schade voor Sony was enorm. De daders wisten onuitgebrachte films, e-mails, salarissen en andere privé-informatie te stelen. Heel lang werd gedacht dat de groeperingen die achter de aanval stond door Noord-Korea was aangestuurd. Echter, nu nog steeds heeft men dat niet kunnen bevestigen. Zou zijn er ook experts die denken in het bewijsmateriaal de hand van Rusland en/of China te zien. Kortom, zoals eerder gezegd, cyberaanvallen zijn verdomd lastig om in kaart te brengen.

Als het toch Noord-Korea zou zijn geweest - wat nog steeds meer dan mogelijk is- dan hebben ze hiermee dus een dubieuze primeur: voor het eerst valt een soeverein land een bedrijf aan in een ander land. En de vraag die vervolgens veel experts zich stelden was: “vanaf wanneer is dit een *act of*

aggression?” en “moet een land op dit soort aanval reageren namens het bedrijf, of namens de hele natie waar het bedrijf zich bevindt?” Wie zal het zeggen. Dit boekje helaas niet, maar het geeft wel voor voor discussie.

2015: Stuxnet bewaarheid

Keer op keer zullen we dit moeten herhalen: we kunnen nooit met 100% zekerheid de origine van een cyberaanval vaststellen. Heel af en toe, met dank aan klokkenluiders zoals Snowden, of verregaand (al dan niet journalistiek) onderzoek worden specifiek aanvallen volledig uit de doeken gedaan.

In 2015, iets meer dan een jaar na de Sony aanval, werd dat waar we voor vreesden bewaarheid: hackers waren er in geslaagd om de elektriciteitsinfrastructuur van Oekraïne deels plat te leggen. Een groepering slaagde er zo in om bijna een kwart miljoen mensen gedurende meerdere uren zonder stroom te zetten. Iedereen keek uiteraard ogenblikkelijk in de richting van Rusland - Oekraïne maakte vroeger deel uit van de voormalige Sovjetrepubliek- daar de aanvallen kwamen van IP-adressen die waren toegewezen aan Rusland. Maar zelfs als dat zou zijn, zonder harde bewijzen dat de hackers ook handelden in naam van de Russische overheid blijft het modderdik kijken wie *op de vingers getikt* moet worden voor de aanval.

Wie het ook waren, één ding staat wel vast: in 2015 waren hackers er voor het eerst in geslaagd om met één welgemikte aanval honderdduizenden mensen in problemen te brengen.

Enkele jaren later, in februari 2021, zou het trouwens weer bijna prijs zijn. Een hacker kreeg toegang tot de systemen die de waterzuivingsinstallaties van Oldsmar (Florida, VS) bediende. Een operator zag op tijd dat z'n muis plots bewoog en de maximum toegelaten hoeveelheid natriumhydroxide waarde van de filters op een dodelijk niveau zette. Er werd gelukkig tijdig ingegrepen (en detectoren verderop in het systeem hadden het vergiftigde water sowieso gedetecteerd), maar het deed wederom de vraag rijzen of onze kritische systemen wel voldoende beveiligd zijn tegen dit soort *lone wolves*.

2015: Scheidingen en zelfmoord

2015 wordt de schaal van cyberaanvallen steeds groter. De hoeveelheden informatie die hackers van bedrijven kunnen bemachtigen kunnen al lang niet meer op een A4'tje afgedrukt worden. Wanneer hackers toegang krijgen tot de privé-servers van hun doelwit kunnen ze vlotjes ettelijke gigabytes, tot zelfs terrabytes, aan geheime informatie stellen. Tegenwoordig hebben we in Europa de GDPR wetgeving die probeert bedrijven duidelijk te maken (en te straffen) dat zij verantwoordelijk zijn om onze data op een veilige manier te bewaren. In 2015 was dat veel minder. De berichten van datalekken in die tijd spraken boekdelen: van zodra cybercriminelen toegang hadden tot de privéservers konden

ze de data zonder problemen lezen. Paswoorden, kredietkaartgegevens, rijksregisternummers, alles stond onbeveiligd (*ongeëncrypteerd*) op de systemen.

Ashley Madison was de tinder voor mensen die een relatie wilden naast hun “officiële relatie”. De site hielp kortom mensen aan een affaire. Hun leuze, “Life is short. Have an affair”, wond er geen doekjes rond. En met hun meer dan 20 miljoen “klanten” was het duidelijk dat ze een lucratief idee hadden. Dat ze tegenwind zouden krijgen was te verwachten. Maar een wind van 12 beaufort? Dat niet.

In juli 2015 plaatste een groep hackers een ultimatum op een website aan het adres van de eigenaars van Ashley Madison: “Haal jullie moreel dubieuze website van het internet, of wij plaatsen meer dan 60 gigabyte aan gestolen data online”. De site werd niet offline gehaald en de hackers “hielden woord.” De gevolgen waren immens, niet zo zeer voor Ashley Madison, wel voor z’n klanten. Plotsklaps kreeg de wereld een lijst te zien waarin honderdduizenden klanten open en bloot aan de schandpaal werden genageld. Mensen werden publieke vernederd. Er is sprake van minstens 2 of 3 zelfmoorden rechtstreeks als gevolg van de lek. Mensen werden ontslagen. Kortom, het lekken van wat uiteindelijk maar een hoop binaire data- nullen en eentjes- was had gevolgen voor relaties, mensenlevens en carrières.

Als positieve noot in dit verhaal halen we hier uit dat dit soort gigantische lekken mensen heeft doen inzien dat ze twee maal moeten nadenken voor ze hun persoonlijke informatie weggeven aan één of andere internet-gigant (het is helaas een les die we jaarlijkse lijken te vergeten, kijk maar naar de populariteit van Tik Tok, Facebook, etc.).



Een stelregel die bedrijven nu hanteren is de volgende: vraag je niet af **of** je gaat gehackt worden maar vraag je af **wanneer** je zal gehackt worden. Dit is een heel andere manier van tegen je beveiligingsprobleem aankijken. Vergelijk het met het in huis halen van een koffer met daarin 10 miljoen euro aan diamanten. Als je je afvraagt of er ooit inbrekers zullen binnen geraken en daar naar beveiligd -waakhonden, videocamera’s rond het huis, dubbel slot- dan heb je daar niets aan als ze vervolgens toch binnen geraken en je koffertje stelen. Veel beter kan je én je huis beveiligen, én ervan uitgaan dat ze de koffer gaan bemachtigen: en je dus maar beter ook ervoor zorgt dat de dieven niets met de diamanten kunnen doen (door bijvoorbeeld je naam er in te graveren).

Kortom: bedrijven moeten data die ze van ons opslaan minstens encrypteren en systemen inbouwen die de data onbruikbaar maken als ze toch gelekt zou worden.

2016: Internet-of-horrors

In onze huizen verschenen steeds meer apparaatjes die via het draadloze netwerk met elkaar en het internet konden communiceren. De term Internet-of-Things (IoT) bracht een weelde aan nieuwe

oplossingen in onze levens. Domotica, wearables, slimme thermostaten, beveiligingssystemen, weegschalen, alles werd én slimmer gemaakt én aan het internet gehangen. Een inherent probleem met veel van deze kleine toestellen is dat ze op het gebied van beveiliging ondermaats presteren. Dergelijke IoT-apparaten werken vaak op batterijen en de makers willen natuurlijk de batterijduur zo lang mogelijk houden. Iedere extra feature die de designers in het apparaat willen steken heeft een kost op die levensduur. Een aspect zoals beveiliging werd dan ook vaak achteraan de lijst van potentiële features geplaatst. Komt daarbij dat IoT-apparaten updaten soms onmogelijk of tenminste omslachtig is. Als er dus een beveiligingslek wordt gevonden in een apparaat dan is de kans bestaande dat dit lek voor altijd aanwezig zal blijven én dus ook kan misbruikt worden.

Het was met andere woorden wachten tot de eerste aanvallen, specifiek gericht op IoT apparaten, zouden plaatsvinden. De meest opvallende aanval gebeurde eind 2016. Malware, genaamd Mirai, verspreide zich als een lopend vuurtje over IoT-apparaten waarvan de malware de standaard paswoord en username kende. Gebruikers die vergeten waren het paswoord aan te passen dat het apparaat heeft wanneer je het uit de doos haalt zaten zo plotseling met een ogenschijnlijk perfect werkend apparaat. Echter, de malware nestelde zich onzichtbaar op het apparaat en wachtte op commando's van de Mirai makers. De malware creëerde met andere woorden een zogenaamde *botnet*, een groot netwerk van besmette apparaten die allemaal commando's kunnen uitvoeren van de *botnet herder*. De Mirai-makers hadden zo een legertje minicomputers onder hun bevel die ze konden zeggen "surf nu allemaal naar die website". Een website die plots tienduizenden gebruikers onverwacht extra te verwerken krijgt zal vaak onder de druk bezwijken en crashen. Kortom, dit Mirai botnet kon zo grote distributed denial-of-service (*ddos*) aanvallen uitvoeren, allemaal omdat gebruikers de paswoorden van hun gloednieuwe apparaatjes niet hadden aangepast. In hun verdediging, het is vaak een erg omslachtig, technisch, proces om het paswoord van een IoT-apparaat aan te passen.

De wildgroei van Internet-Of-Things apparaten heeft ervoor gezorgd dat hackers een grote hoeveelheid extra mogelijkheden hebben bijgekregen om op huis en bedrijfsnetwerken te infiltreren.



Een dubieuze (deels betalende) site, **shodan.io**, heeft als enige doel alle internet-of-things apparaten in kaart te brengen die zichtbaar zijn vanop het internet. Deze "google voor IoT" toont zelfs om wat voor apparaten het gaat en welke bijvoorbeeld nog steeds het standaard (default) paswoord hebben.

2017: Ransomware wordt gemeengoed

De virussen in de vorige eeuw dierven al eens je data te verwijderen. Lastig, maar erg duidelijk: je data was je kwijt, tenzij je ergens een backup had liggen. De nieuwe virussen gingen echter een stapje verder: ze versleutelden al je data (vaak ook je backups als je zo dom was geweest deze op het zelfde apparaat te hebben) én vroegen vervolgens losgeld in ruil voor je data. De naam *ransomware* kon, helaas,

niet beter gekozen zijn. Menig particulier betaalde ogenblikkelijk om de eenvoudige reden dat de ransomware de gebruiker nog een uitweg aanbod daar ransomware vaak werd “binnengehaald” door een gênante actie (bv illegale software downloaden, op reclame voor vage pornosites klikken, etc). Voor particulieren was ransomware vooralsnog irritant. Maar wat als de ransomware bedrijfskritische data begon te encrypteren? Dit is exact wat er gebeurde in 2017 met de Wannycry en Petya Ransomware. Deze malwares sloegen er in om banken, hospitalen, havenbedrijven en menig ander groot (en klein) bedrijf te besmetten. De economische schade werd geschat op bijna 4 miljard dollar vanwege het lamleggen van de productie (of in het geval van enkele ziekenhuizen: het redden van mensenlevens).

De schade én de losgeldbedragen worden ook steeds groter. Zo was er het voorval met Garmin in de zomer van 2020 dat niet alleen de populaire loop-tracking-diensten gedurende meerdere dagen uit de lucht haalde, maar er ook voor zorgde dat menig vliegtuig niet mocht vliegen omdat de Garmin Pilot apps niet werkten waardoor de piloten geen up-to-date aeronautische plannen voorhanden hadden. Het is nooit geweten of Garmin het losgeld (10 miljoen dollar!) wel of niet heeft betaald, vast staat wel dat ransomware tegenwoordig een, helaas, erg lucratieve handel is geworden voor cybercriminelen.

En nu: de geopolitiek macht van sociale media en grote datalekken

2016 ging er een schokgolf doorheen de wereld. Tegen alle verwachtingen in won Donald J. Trump de presidentsverkiezingen na een bitsige strijd tegen Hillary Clinton. Dat social media een belangrijke rol zouden spelen dit decennium was al lang voorspelt. Facebook, Twitter, Google en konsoorten hadden miljarden gebruikers die met plezier hun privacy te grabbel gooiden in ruil voor dagelijkse dopamine-shots dankzij *likes* en *retweets*. Met dank aan gigantische onder andere Russische *troll farms* -organisaties die duizenden fake social media accounts aanmaken en zo mee de social media algoritmes beïnvloeden om bepaalde informatie te *nudgen* in de gewenste politieke richting- kon Trump honderdduizenden potentiële twijfelaars doen inzien dat hij het juiste antwoord is om hun problemen op te lossen. De inmenging van Rusland in een buitenlandse verkiezing (een daad waar ook de Verenigde Staten in het verleden zich schuldig aan heeft gemaakt) was ontluisterend vanwege de schaal waarop het gebeurde. Het toonde de almacht van de grote Silicon Valley bedrijven en hoe zij op geopolitiek niveau een belangrijke speler zijn. Iets dat vervolgens nogmaals bevestigd werd door het simultaan plaatsgevonden Cambridge Analytica schandaal, dat niet alleen mede ervoor gezorgd heeft dat Trump president werd, maar dat hoogstwaarschijnlijk ook een grote groep twijfelaars heeft kunnen overhalen om een pro-Brexit stem uit te brengen.

Drie jaar later zagen onderzoekers een soortgelijk fenomeen tijdens de verkiezingen van de Europese Unie in 2019. Een rapport toonde aan dat Rusland actieve misinformatie campagnes organiseerde om zo de verkiezingen te beïnvloeden. Ze gebruiken hierbij zogenaamde *bad actors*, fake social media accounts die (al dan niet fake) nieuws verspreiden dat “in de winkel van Rusland”. Uit het onderzoek bleek dat de toenmalige belangrijkste EU-mandatarissen (Juncker, King, Tajani, etc.) soms tot 20%

volgers op Twitter hadden die eigenlijk *bad actors* waren.

De voorbije jaren is er een (lichte) kentering bezig inzake de macht van de social media bedrijven, maar het blijft een feit dat momenteel wij alleen grotendeels afhankelijk zijn van door artificiële intelligentie aangedreven algoritmes die bepalen welke informatie wij willen/zouden/moeten consumeren, ieder uur van de dag. Zolang echter data het nieuwe goud is en bedrijven dit vrij kunnen bewaren (GDPR poogt dit in te perken) zullen zij hun algoritmes kunnen blijven voeden en trainen om nog griezeliger/knapper te maken.

Het gevolg van die *datahoarding* is echter ook dat datalekken ook steeds nefastere gevolgen hebben. Daar waar we bij Ashley Madison het nog ging om een dikke 20 miljoen user accounts, medio 2021 zijn het aantal accounts dat bij een datalek betrokken zijn soms vertienvoudigd - de MGM Grand Hotels keten zag in de zomer van 2020 plots 142 miljoen van z'n gast-accounts te koop staan voor een schamele 3000 dollar in bitcoin.

En de toekomst?

Een glazen bol hebben we niet, maar vast staat dat het er niet op zal verbeteren. Zoals gezegd gaan bedrijven uit van *when* in plaats van *if* als het gaat over de vraag of ze al dan niet ooit gehackt zullen worden. Daarnaast zien we dat hoogtechnologische producten meer en meer ingeburgerd geraken in het cybercrimemilieu. Deep fakes video van bekenden zijn nu nog “grappig”, maar de realistische beelden (afbeeldingen, video én nu zelfs ook spraak) die ze kunne produceren zijn al even niet meer te onderscheiden van het echte en zullen dus meer en meer kunnen gebruikt worden voor sextortion en soortgelijke schandalen. Dit soort trends zullen nog jaren *fake news* hoogtij laten vieren waardoor ook toekomstige verkiezingen interessante doelen blijven voor andere mogelijkheden om hun stempel te drukken op geopolitieke tegenstanders.

Het is erger, maar...

Dus ja, het wordt helaas erger. De wapenwedloop in de cyberwereld gaat beangstigend snel vooruit en het wordt moeilijker en moeilijker om als “normale sterveling” er een antwoord tegen te geven. Als een IoT botnet van 10 miljoen apparaten morgen beslist om de infrastructuur van jouw KMO plat te leggen, dan zullen ze daar in slagen, ongeacht de miljoenen euro's die je hebt geïnvesteerd in *firewalls*, *intrusion detection systems*, *virusscanners* en *honeypots*.

Aan de andere kant heeft de wapenwedloop er wel voor gezorgd dat onze infrastructuur ook steeds complexere aanvallen kan weerstaan. Hierdoor wordt het voor huis-tuin-en-keuken malware een pak moeilijker om nog computers van thuisgebruikers te besmetten.

Maar laten we deze cyberstropers geen vrij spel geven! Laten we leren van hun technieken om zo zelf onze systemen en personeel te *hardenen* en te beschermen tegen wat niet anders dan het “wilde westen van het Internet” (dixit komiek Steven Wright) kan genoemd worden.

GDPR en privacy

Cryptografie

Waarom cryptografie?

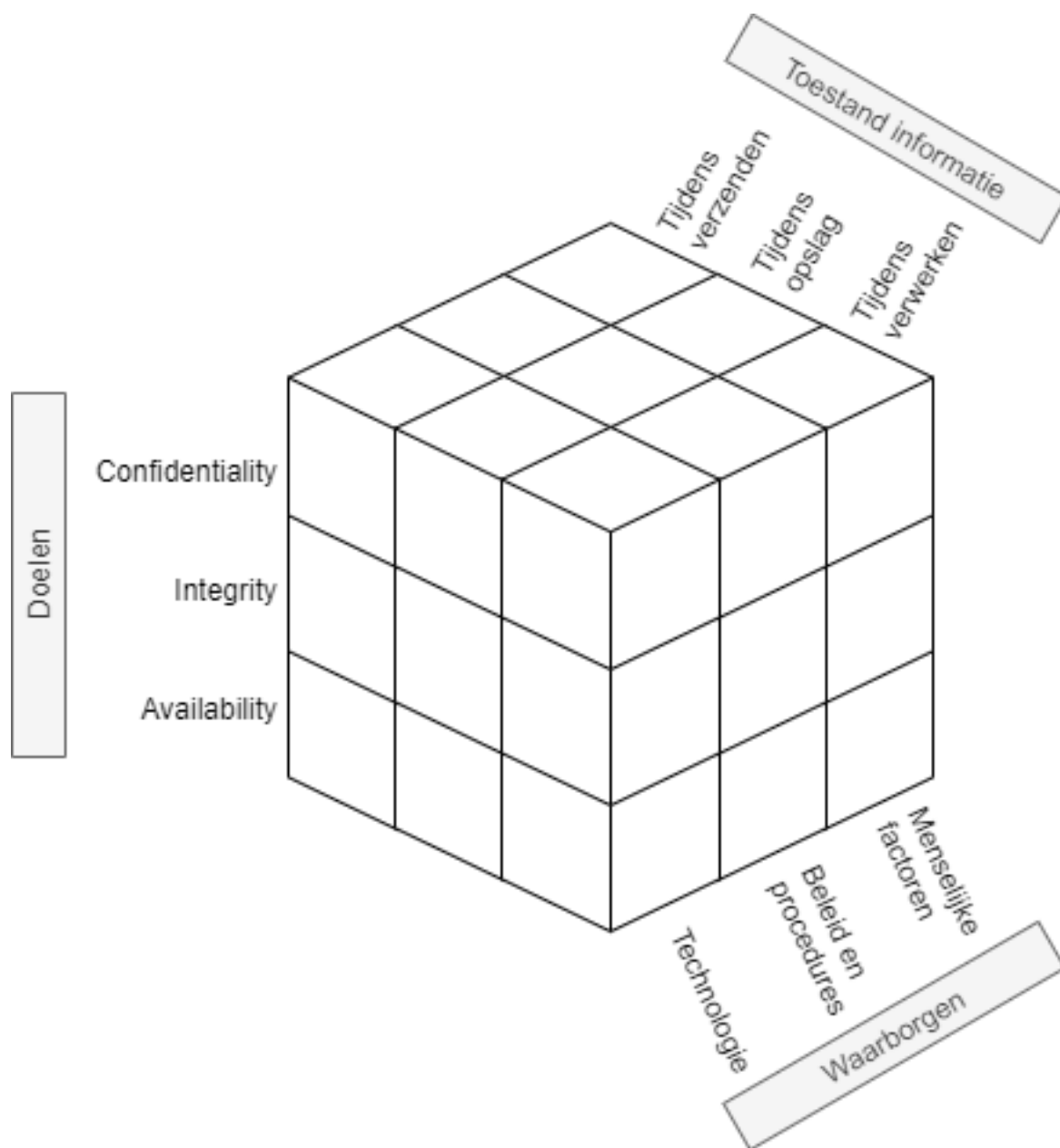
CIA en het security model

Data (of informatie), in welke vorm dan ook (berichten over een netwerk, bestanden op een harde schijf, tekst in een database), moet beschermd worden, dat beseffen we nu. Het doel van onze data is dat deze voldoet aan het acroniem **C.I.A** wat staat voor:

- **C** voor “**confidentiality**”: vertrouwelijkheid. De data kan enkel door zij die er recht toe hebben gebruikt worden. We gaan dit onder andere oplossen met behulp van encryptie en paswoorden.
- **I** voor “**integrity**”: integriteit. We moeten weten of onze data onbeschadigd is en niet werd aangepast door derden (of storingen). Bij bestanden gaan we bijvoorbeeld werken met zogenaamde (secure) hashes.
- **A** voor “**availability**”: beschikbaarheid. Data die niet door rechtmatige gebruikers kan bereikt worden is onbestaande data. Zogenaamde “denial-of-service” (dos) aanvallen hebben als doel deze peiler van CIA aan te vallen. availability is een breed veld en wordt onder andere opgelost door backups, redundante servers enerzijds, en preventieve maatregelen anderzijds zoals firewalls, load balancers, etc.

De zogenaamde McCumber kubus, ontwikkeld door John McCumber in 1991, geeft een goed beeld weer waarom het steeds belangrijk is goed te beseffen binnen welke context we praten. Deze kubus stelt een model voor dat kan gebruikt worden om je ervan te vergewissen dat je aan alles denkt wanneer je je informatie wilt beschermen. De kubus bestaat uit 3 dimensies en iedere dimensie bestaat uit een aantal aspecten. **Enkel wanneer we alle aspecten van alle dimensies in onze beveiligingsaanpak voorzien kunnen we hopen dat we onze C.I.A. doelen hebben bereikt.**

Om ons doel te bereiken (C.I.A.) moeten we ervoor zorgen dat we dit toepassen op alle vormen die onze data kan hebben (opslag, verzenden, verwerken). Dit kunnen we tewerkstellingen door technologische oplossingen (zoals encryptie wat zo meteen wordt uitgespit), maar een niet onbelangrijke factor zijn ook de mensen die met de data moeten werken. Als zij zich niet aan de afspraken (procedures) houden en hun paswoorden gewoon op postits aan hun scherm hangen, dan mag je een nog zo’n dure firewall hebben, het zal niet baten.



Figuur 0.1: De McCumber kubus

Encryptie

Een grote pijler van CIA, confidentiality, wordt opgelost met behulp van encryptie, namelijk het versleutelen van onze data met behulp van een geheime sleutel. Door deze te versleutelen wordt deze onleesbaar voor personen die de geheime sleutel niet hebben (en bijgevolg niet geautoriseerd zijn om de data te mogen lezen). De moeilijkheid van een goed cryptografisch systeem is dat de data op een

zodanig manier met versleuteld worden dat het quasi onmogelijk is om zonder sleutel de originele data terug te vinden. We spreken hierbij over de originele data als de *plaintext* en de geëncrypteerde data als *ciphertext*. De ontvanger van een ciphertext moet deze, als hij de juiste sleutel heeft, terug kunnen omzetten naar de originele plaintext.

Er zijn al veel encryptie algoritmes de revue gepasseerd doorheen de geschiedenis van de mens. Al van in de tijd van de Romeinen werd er aan cryptografie gedaan. Mensen hebben altijd gevoelige data gehad waar vertrouwelijk mee moest om gesprongen worden. Naarmate de **cryptanalyse** (dat is het proberen ontcijferen van een ciphertext zonder dat je de geheime sleutel hebt) evolueerde moesten ook de cryptografische algoritmes verbeteren. Ook hier zien we weer diezelfde wedloop tussen digitale stropers en cyberboswachters. Hoe sterker onze computers worden (met dank aan de wet van Moore) hoe krachtiger onze algoritmes moeten worden. De eenvoudigste vorm van cryptanalyse, bruteforcing, is rechtstreeks afhankelijk van de snelheid van de computer. Hoe meer sleutels per seconde een computer kan testen, hoe sneller de originele sleutel kan gevonden worden.



De volledige geschiedenis van de cryptografie hier vertellen zou ongeveer 1200 pagina's vereisen. Het briljante boek "The Codebreakers" van David Kahn is een aanrader voor eenieder die meer willen weten over deze boeiende geschiedenis. Laat de 1200 pagina's je niet afschrikken, het boek leest als een echte thriller.

Alle bestaande cryptografische systemen kunnen op verschillende manieren gekarakteriseerd worden (bron Network Security Essentials, door William Stallings):

- De **acties** die op de data wordt uitgevoerd om deze te encrypteren:
 - Substitutie: een teken door een ander teken vervangen.
 - Transpositie: een teken naar op een andere plek in de tekst zetten.
 - Product: een combinatie van meerdere substituties en transposities.
- Het **aantal sleutels** dat nodig is:
 - 1 sleutel, ook wel "private encryption" genoemd.
 - 2 sleutels, ook wel "public encryption" genoemd.
- De **manier** waarop de data wordt verwerkt:
 - Als een blok data, blok per blok.
 - Als een stream, teken per teken.

Kerckhoffs principe

We gaan zo meteen bekijken hoe encryptie effectief gebeurt, maar we willen al even een mythe onderuit halen. Binnen encryptie heb je de *principes van Kerckhoff*, 6 regels die in de 19e eeuw werden vastgelegd waarin encryptie-algoritmes moeten voldoen om als veilig beschouwd te worden. Sommige principes zijn, onder ander door onze steeds krachtige computers, niet meer relevant, meer 1 blijft ongelooflijk belangrijk: " het kennen van het gebruikte encryptiealgoritme door de *tegenstander* is geen probleem, het is enkel de geheime sleutel die ten allen tijde uit de handen van de tegenstander moet blijven."

Dit ogenschijnlijk eenvoudige zinnetje is veel zeggen: **je sleutel (of paswoord) is wat je het beste moet beschermen. Zonder kennis van de sleutel zou iemand nooit toegang mogen krijgen tot versleutelde data, ongeacht dat geweten is met welk systeem de data werd gecijferd.**

Security through obscurity is al lang een dubbel snijdend zwaard binnen de security wereld. Enerzijds is het niet aangeraden om met veel tamtam aan te kondigen hoe jij je data beveiligd. Anderzijds geeft het je mogelijk een vals gevoel van veiligheid (*snake's oil*) daar het geheimhouden van je algoritme en systemen geen garantie is dat deze ook effectief veilig zijn. In de 21e eeuw zijn de meest gebruikte encryptie-algoritmes publiek gekende algoritmes die door duizenden experts aan de tand zijn gevoeld. De kans dat er dus (bewuste) fouten in dergelijke standaarden zit is véél kleiner dan wanneer je met een zogenaamd *proprietary* systeem werkt waarvan de werking angstvallig geheim wordt gehouden.

Finaal draait alles op het geheimhouden van je sleutel, iets dat we telkens weer in dit boek zullen herhalen!



Let op encryptiesystemen die zichzelf verkopen met zinnen zoals "10 jaar nodig op een gewone laptop om alle sleutels te testen". Dit zou kunnen doen vermoeden dat je dus voor minstens 10 jaar goed zit (we gaan er even vanuit dat de gemiddelde cryptanalist maar toegang heeft tot 1 laptop, wat uiteraard in de echte wereld niet zo is). De gemiddelde tijd van voorgaande systeem om te bruteforcen is 5 jaar, de helft.

Stel dat je een sleutel hebt die bestaat uit 8 karakters. Een karakter is een letter van a tot z (geen onderscheid tussen hoofd en kleine letters en geen getallen of speciale tekens). Er zijn 26^8 mogelijke sleutels (we gaan ervan uit dat de sleutel exact 8 karakters moet bevatten). Een computer kan 1 miljoen sleutels per seconde testen. De duur om alle mogelijke sleutels te testen is dus $(26^8)/1\,000\,000$, oftewel 208 827 seconden, pakweg 58 uur. Intuïtief zou je kunnen denken dat je dus meer dan 2 dagen "veilig" zit, wat niet zo is. De kans dat de eerste sleutel die je test reeds de juiste is, is even groot als dat het de laatste sleutel is. Kortom, gemiddeld gezien zal de sleutel in de helft van de maximum tijd gevonden was, oftewel 29 uur.

De eerste algoritmes

Het doel van ieder encryptie-algoritme is dus om data zodanig te versleutelen zodat enkel eigenaars van de gebruikte sleutel de originele tekst kunnen terugvinden. We vertelden net dat encryptiealgoritmes kunnen onderverdeeld volgens de actie die ze uitvoeren: substitutie, transpositie of een combinatie. We tonen van iedere variant nu een historisch voorbeeld.

Substitutie: Caesar encryptie

De Caesar encryptie (naar Julius Caesar) bestaat uit een eenvoudige substitutie algoritme. De sleutel is een getal tussen 1 en 25 en geeft aan door welk element uit het alfabet een teken wordt aangepast, als volgt:

- Ieder element wordt voorgesteld als een cijfer. A krijgt de waarde 1, B wordt 2,... Z wordt 26.
- Als de sleutel het getal 3 is, dan zal nu iedere letter A in de tekst vervangen worden door het teken 1+3, dus D. Iedere B wordt een E, enzovoort.
- Indien er een “overflow” is achteraan komen we uiteraard terug naar voor in het alfabet. Iedere Z wordt dus een C, iedere Y een B, enzovoort.



De modulo operator (%) is erg nuttig bij substitutie-algoritmes zoals bij Caesar encryptie. De modulo operator geeft de rest weer wanneer de linkse door de rechtse operator zouden delen. $19\%5$ geeft dus 4 als resultaat. Je kan de operator gebruiken om snel te weten wat de waarde van een teken wordt bij Caesar-encryptie als volgt:

`teken % sleutel => nieuw teken`

Als je dus een sleutel hebt met waarde 7 en je wilt weten wat de waarde van Y (element 25) wordt dan schrijf je:

`25 % 7`

Dit zal dus 4 worden, oftewel een D.

Het Caesercipher wordt ook wel kortweg *Rot* genoemd, naar het woord *rotatie*. Een cijfer erachter geeft dan aan welk de te gebruiken sleutel is. Rot4 wil dus zeggen dat alle elementen 4 plaatsen opgeschoven moeten worden.



Merk op dat Rot13 (ook wel *Caesaralfabet genoemd) een speciale sleutel is. Als je namelijk 2 maal na elkaar Rot13 toepast op een tekst (eerst op de plaintext, dan op de resulterende cipertext) dan verkrijgt men terug de originele tekst.

Uiteraard kan iedere weldenkende mens in de 21e eeuw een Caesar-encryptie bruteforcen. Het aantal mogelijk sleutels beperkt zich tot 25 mogelijkheden (sleutel 26 zal resulteren in géén encryptie: je plaintext en ciphertext zullen identiek zijn) en je kan dit dus snel testen.

Door **frequentieanalyse** op de ciphertext toe te passen kan men ook de plaintext terugvinden zonder te moeten bruteforcen. Indien de plaintext een tekst in ,bijvoorbeeld, het Nederlands is, dan kunnen we gebruik maken van de statistische eigenschappen van een taal. Zo weten we dat bepaalde letters in een standaard Nederlandstalige tekst meer of minder vaak voorkomen. De letter e komt bijvoorbeeld veel vaker voor dan de v. Daar iedere letter in de encryptie door een andere wordt vervangen, is het dus voldoende om te ontdekken (a.d.h.v. frequentieanalyse) welke letter(s) het meest of minst voorkomen om je zo een vermoeden te geven van de originele letter.



Dit verklaart ook waarom je best je te encrypteren berichten zo kort mogelijk houdt. Hoe minder tekens, hoe minder goed je frequentieanalyse zal werken. Een andere veelgebruikte fout (in klassieker encryptie) was dat de verzender bijvoorbeeld voorspelbare tekst ging encrypteren. Als je weet dat de verzender altijd begint met “Geachte” in z’n berichten, dan is de kans groot dat de eerste 7 tekens in de ciphertext deze plaintext voorstellen.

Het principe van Caesar-encryptie, de substitutie, blijft echter overeind staan en zal je nog zien terugkomen in de komende algoritmes.

Transpositie: scytale encryptie

Bij transpositie-algoritmen gaan we de positie van de karakters veranderen. De sleutel kan hierbij bepalen op welke manier dit moet gebeuren. De Oude Grieken gebruikten een zogenaamde scytale om aan transpositie-encryptie te doen. Een scytale was een lange stok bestaande uit 3 of meerdere lange zijden. De boodschap werd op een lang lint geschreven en dit lint werd dan over de skytale gedraaid. De sleutel gaf aan uit hoeveel vlakken de te gebruiken scytale moest bestaan. Ieder karakter van de plaintext (het lint) kwam op een andere zijde te liggen. Vervolgens werden alle letters op 1 zijde achter elkaar gezet, en dit werd herhaald voor iedere zijde: dit werd de ciphertext die werd doorgestuurd.

Om de nu de cipertext decrypteren werd een onbeschreven lint over de juiste scytale gelegd. Vervolgens werd de verkregen op dit lint, zijde per zijde, beschreven. Als de ontvanger dan het lint ontrolde kreeg hij terug de originele tekst te zien.



Het voordeel van een transpositiecipher is natuurlijk dat een zogenaamde “known plaintext” aanval iets moeilijker wordt. Een veel gebruikte manier die cryptanalisten vroeger gebruikten is de kennis die ze hadden van delen van de plaintext. Als geweten was dat het bericht altijd begon met “Beste dokter” dan was dit al een goede aanzet om van hieruit verder te werken.

Uiteraard zijn er tal van varianten mogelijk om transpositie te doen. Eerst kan je beslissen om je plaintext in een bepaalde vorm te plaatsen: bijvoorbeeld in 10 kolommen. Vervolgens kan je dan, gebaseerd op de sleutel, beslissen in welke volgorde je de kolommen achter elkaar plaatst om de originele tekst te krijgen. Dit is een zogenaamd *route cipher* wat onder andere werd gebruikt tijdens de Amerikaanse Burgeroorlog.



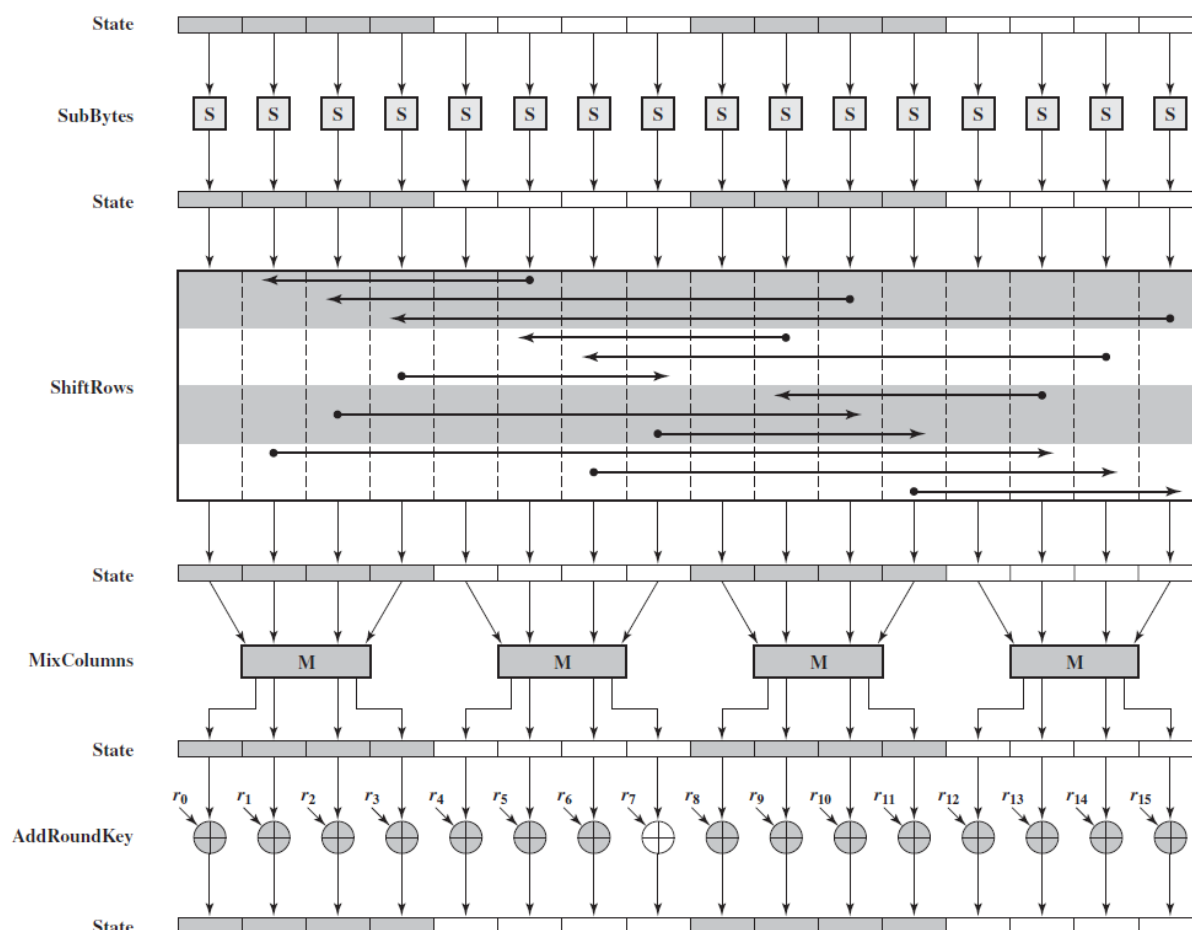
Figuur 0.2: Bron Wikipedia

Combinatie

Het spreekt voor zich dat een combinatie van een transpositiecipher en een substitutiecipher je encryptie nog versterkt. Veel moderne algoritmen kunnen nog steeds herleid worden tot een sequentie van meerdere basisvormen na elkaar.

De **Advanced Encryption Standard (AES)** is in de 21e eeuw zo’n beetje de de facto standaard als

het aankomt op symmetrische encryptie (d.w.z. encryptie waar maar 1 sleutel voor nodig is, verder meer hierover). Als we echter eens het algoritme opengooien en een enkele *encryption round* bekijken (AES bestaat uit een sequentie van deze rondes) dan zien we dat de bits die bovenaan binnenkomen (*state*) vervolgens een combinatie van substituties (*sub*) en transposities (*mixcolumns* en *shiftrows*) ondergaat.



Figuur 0.3: Bron Wikipedia

We gaan AES nog terugzien opduiken wanneer we gaan bekijken hoe draadloze netwerken worden beveiligd. Als Belg mogen we trouwens erg fier zijn op deze wereldwijd gebruikte Amerikaanse standaard. Je zal later ontdekken waarom dat zo is!



Doel van dit hoofdstuk is ook aantonen dat je geen wiskundig wondertalent moet zijn om de basisconcepten van cryptografie te begrijpen. Hier en daar neem ik wat vrijheden om bepaalde stappen te vereenvoudigen, maar de essentie van de algoritmen blijft wel bewaard en daarmee, hopelijk, ook de eenvoudigheid (en dus elegantie) ervan.

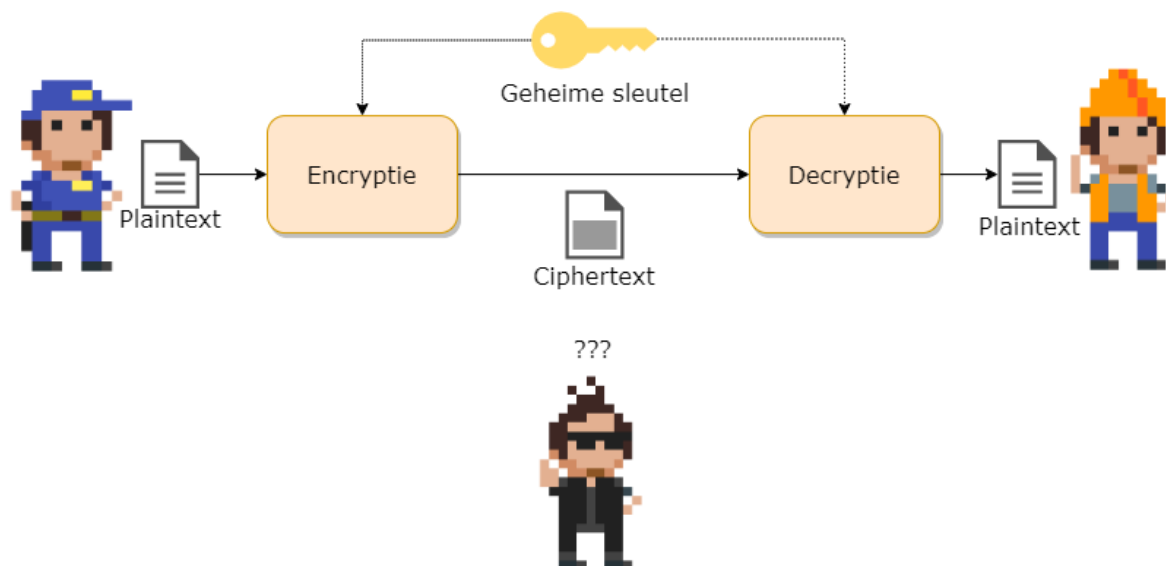
Cryptanalyse

TODO:

- Sleutel lengte en permutaties berekenen afh van alfabetgrootte
- Tijd om te bruteforcen tabel
- cryptanalytics attack
- cryptanalytic attacks vs bruteforce
- Bruteforce vs dictattack
- Noot omtrent quantum computers

Symmetrische encryptie

Er zijn 2 soorten encryptiesystemen als we kijken naar het aantal sleutels. Symmetrische systemen zijn systemen waarbij maar 1 sleutel nodig is: zowel ontvanger als verzender gebruiken dezelfde sleutel. De term symmetrisch verwijst naar het feit dat het algoritme exact hetzelfde doet aan beide zijden. Het enige verschil is dat bij de verzender de plaintext in het systeem wordt gestoken, wat resulteert in een ciphertext. Terwijl de ontvanger de ciphertext in het systeem plaatst om een plaintext te krijgen.



- De symmetrische encryptiesystemen zijn de oudste vorm: alle klassieke algoritmes waren van dit principe. Asymmetrische systemen zijn pas in de 20e eeuw ontwikkeld (circa 1970).
- Voorbeelden van bestaande symmetrische encryptiesystemen zijn: AES, DES, IDEA, RC4, Blowfish, etc.

Dit type encryptie is nog steeds het meest gebruikt en wordt overal gebruikt waar data op een veilige (confidentiality) moet bewaard, verstuurd of verwerkt worden.

Sleuteloverdracht

De moeilijkheid bij symmetrische systemen is de sleuteloverdracht. Daar ontvanger en verzender dezelfde sleutel hanteren is het natuurlijk belangrijk dat deze de sleutel op een veilige manier kunnen uitwisselen. Dit probleem wordt niet opgelost door symmetrische cryptosystemen. Afhankelijk van de context kan deze uitwisseling op verschillende manieren gebeuren:

- Via een asymmetrisch encryptiesysteem dat wél sleutels op een veilige manier kan uitwisselen (zie verder).
- Via een beveiligd kanaal, in eender welke vorm (bijvoorbeeld fysiek de sleutel aan de andere persoon geven of zeggen, deze opsturen via een reeds bestand opgezet symmetrisch encryptie-kanaal, etc.)

Block en Stream cipers

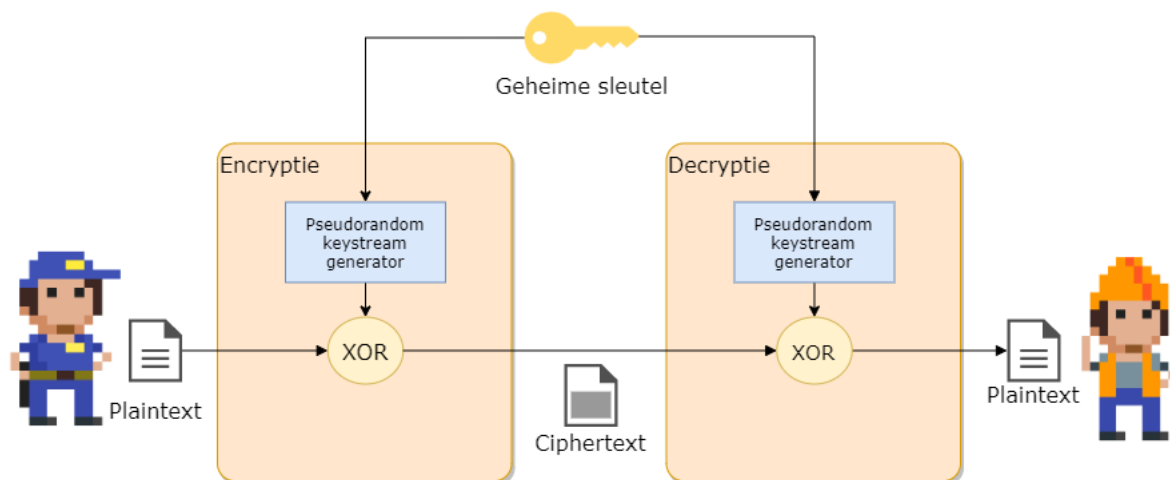
Er zijn 2 soorten symmetrische encryptie-ciphers als we kijken naar de manier waarop ze de te encrypteren data verwerken:

- **Streamciphers:** hierbij wordt de data letterlijk als een stream van tekens, teken per teken geëncrypteerd (RC4, etc.). Voor ieder teken dat verwerkt wordt zal er exact één geëncrypteerd teken gegenereerd worden. Dit soort algoritmes zijn over het algemeen sneller dan de blockciphers.
- **Blockciphers:** de data wordt in blokken (van bijvoorbeeld 128 tekens) verwerkt (AES, DES, 3DES, etc.) Deze vorm komt heden ten dage vaker voor.

Streamciphers

De werking van een symmetrisch stream cipher is verrassend eenvoudig en bestaat uit 2 delen:

- Een pseudorandom keystream generator: deze zal de sleutel als het ware expanderen naar een sleutel met de zelfde lengte als de stream, genaamd een **keystream**. Daar we met een stream werken zal deze generator teken per teken genereren. Hoe dit gebeurt leggen we verderop uit.
- De **xor** of “exclusieve of” functie: deze zal de plaintext naar een ciphertext omzetten door de plaintext met de keystream samen te voegen.



Aan de ontvanger zijde gebeurt exact hetzelfde. **Enkel indien de ontvanger dezelfde sleutel gebruikt, zal deze dezelfde keystream kunnen genereren, en bijgevolg enkel dan de originele plaintext verkrijgen.**

Het hart van een symmetrisch streamcipher is dus enerzijds de xor-functie én, belangrijker, de manier waarop de keystream wordt gemaakt.

De XOR functie

De waarheidstabel van de XOR-functie is de volgende:

Plaintext input	Keystream input	Ciphertext output
1	0	1
0	1	1
0	0	0
1	1	0

De xor-functie wordt in schema's aangeduid door een cirkel met een plusje in:



De XOR-functie heeft de fijne eigenschap dat je deze dus voor encryptie kan gebruiken.

Beeld je in dat we het bericht 1010 willen versleutelen, en we hebben een gegenereerde keystream 1101. Als we deze *XOR*'n dan geeft dit 0111. Dit is dus de cipertext. Als de ontvanger dezelfde keystream kan genereren en deze *xor*'d met de verkregen ciphertext, dan krijgt deze terug de originele plaintext.

De keystream generator

De keystream generator heeft dus als doel om voor iedere karakter dat moet geëncrypteerd worden een bijhorend keystream karakter te maken. Deze karaktergeneratie moet onvoorspelbaar zijn (*random*) tegenover de sleutel die wordt gebruikt en het voorgaande karakter dat werd gemaakt. Echter, dit moet wel PSEUDO (*schijn*)-willekeurig zijn: dezelfde sleutel als begintpunt (*seed*) moet dezelfde reeks genereren.

De kracht (en zwakte) van een symmetrisch streamcipher ligt in de implementatie van de manier waarom deze keystream generator werkt. Mogelijke zwakheden kunnen bijvoorbeeld zijn dat de gegenereerde stroom informatie van de sleutel “lekt” naar de keystream (wat desastreuze gevolgen bleek te hebben bij de originele wifi-security (WEP) waarover later meer) of een voorspelbare “randomiteit” van de keystream?



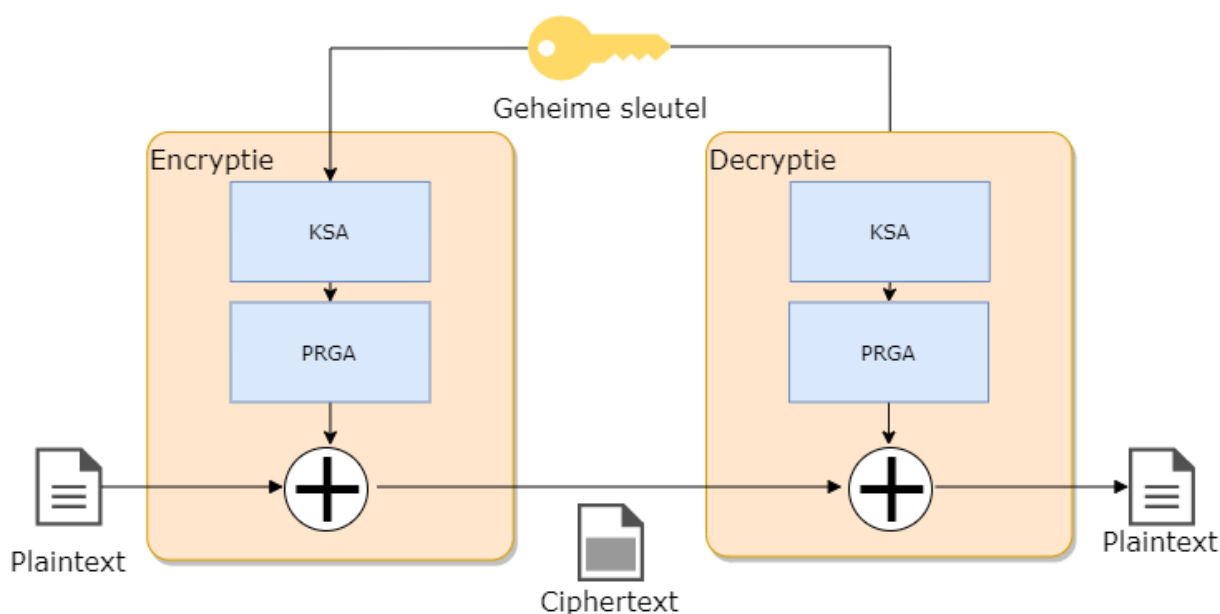
Om aan encryptie te kunnen doen hebben we systemen nodig die onvoorspelbaar zijn. Als de aanvaller kan voorspellen wat de uitvoer van een onderdeel van de encryptie zal zijn, dan kunnen we geen confidentiality en/integrity voorzien. Kortom, we hebben algoritmes nodig die willekeurige getallen kunnen generen die 100% onvoorspelbaar zijn. Net zoals het werpen van een dobbelsteen niet voorspeld kan worden, zo ook moeten onze algorithmes een (digitale) dobbelsteen hebben.

Digitale systemen die perfect willekeurige getallen genereren noemt men **random number generator** (RNG). Uiteraard moet een RNG geprogrammeerd kunnen worden: dat behelst dus een algoritme. Een algoritme is per definitie “voorspelbaar”. Alles hangt daarom af van de invoer die het algoritme gebruikt om random getallen te beginnen genereren. We spreken dan van een **pseudo random number generator** (PRNG), pseudo (**schijnbaar**) omdat de uitvoer afhankelijk is van het startgetal, de zogenaamde **seed**. Die seed kan bijvoorbeeld de encryptiesleutel zijn: enkel met dié sleutel zal het algoritme dezelfde reeks getallen generen. Er zijn echt ook systemen die bijvoorbeeld de staat van een flipflop als startpunt gebruiken: wanneer je een flipflop aanzet kan je niet voorspellen of deze op 1 of 0 zal staan (daar deze staat beïnvloed wordt door de elektromagnetische straling). Uiteraard is een dergelijke seed voor een keystreamgenerator nutteloos, daar zowel verzender én ontvanger dezelfde reeks getallen moeten kunnen genereren.

RC4 tot op het bot

Laten we eens één van de meestgebruikte streamciphers bekijken, het RC4 cipher. Dit algoritme, ontwikkeld Ron Rivest (de afkorting staat trouwens voor *Rons Cipher 4*), wordt gebruikt onder andere om een beveiligde SSL-tunnel (zie later) op te zetten en zit in het hart van veel geëncrypteerde communicatiekanalen. Het heeft weliswaar enkele zwakheden, maar mits juist toegepast kunnen die grotendeels omzeild worden.

RC4 werkt zoals we eerder verklaarden hoe een stream cipher werkt: het heeft een keystreamgenerator en zal de keystream vervolgens XOR'n met de plaintext. Eerst zal de ingevoerde sleutel (die 40 tot 2048 bits lang mag zijn) omgezet worden naar een compatibele werksleutel met behulp van een **Key scheduling algorithm** (KSA). Deze werksleutel zal dan als seed gebruikt worden om een kestream in het **Pseudo-random generator algorithm** (PRGA) te maken.



KSA De **KSA** heeft al doel om, de ingevoerde 40 tot 2k-bit sleutel om te zetten naar een compatibele sleutel voor de PRGA. Het doet dit volgens een eenvoudig algoritme:

Stap 1: plaats de ingevoerde sleutel in een array (**T**) van 256 karakters. Herhaal de sleutel indien nodig.

Stap 2: Maak een array (**S**) aan, ook van 256 karakters, en plaats er de waarden 0 tot en met 255 in.

Stap 3: permuteer (*transpositie*) de elementen in de array T met behulp van de array S als volgt:

```
j = 0
for i = 0 tot 255
```

```
{  
    j = (j + S[i] + T[i]) % 256  
    Verwissel(S[i],S[j])  
}
```

Deze stap zal dus de elementen in de sleutelarray S naar nieuwe posities in de T array plaatsen en deze ook de hele tijd van plek wisselen. De index j is afhankelijk van de sleutelwaarde en zorgt er dus voor dat iedere sleutel een unieke array T zal opleveren.

Uitgewerkt voorbeeld van KSA Stel dat onze sleutel “ab” is. De decimale ASCII-waarden van a en b zijn 97 en 98 respectievelijk. Onze array T zal dus bestaan uit 128 keer de waarden 97 en 98 na elkaar aan de start:

Index	Waarde
S[0]	97
S[1]	98
S[2]	97
etc.	

Stap 2 genereert de tabel T:

Index	Waarde
T[0]	0
T[1]	1
T[2]	2
etc.	

Als we dan stap 3 toepassen dan krijgen we na de eerste iteratie van de loop (i=0):

$j = (0 + S[0] + T[0]) \% 256$

oftewel

$j = (0 + 0 + 97) \% 256 \Rightarrow j \text{ wordt } 97$

De eerste wissel die in S zal plaatsvinden is dan `Verwissel(S[0],S[97])`

S ziet er dan als volgt uit na de eerste iteratie:

Index	Waarde
S[0]	97
S[1]	1
S[2]	2
...	
S[97]	0
etc.	

En dit herhalen we nog 255 keer.

PRGA Nu we een compatibele sleutel T hebben kan de keystream generatie van start gaan. Deze bestaat uit een loop die blijft doorgaan telkens een nieuw plaintext karakter binnenkomt, als volgt:

```
i = 0
j = 0
Herhaal telkens keystream karakter nodig is
{
    i = (i+1) % 256
    j = (j + S[i]) % 256
    Verwissel(S[i], S[j])
    k = S[(S[i]+S[j]) % 256]
    output k naar keystream
}
```

Zoals je ziet zal dus de array S de hele tijd van “gedaante” veranderen (hij blijft bestaan uit de getallen 0 tot en 255 maar al lang niet meer in volgorde) en telkens zal het algoritme één specifieke waarden (tussen 0 en 255) uit de array teruggeven als keystream karakter.

Uitgewerkt voorbeeld van PRGA Als we verder werken met de tabel K van het vorige uitgewerkte KSA voorbeeld, dan krijgen we dus bij iteratie 1 van de PRGA



We veronderstellen even dat we de KSA niet verder hebben uitgevoerd en de tabel S dus dezelfde is gebleven als op het einde van het voorbeeld wat in het echt niet zal zijn.

```
i = (0+1) % 256 => 1  
j = (0+97) % 256 => 97  
Verwissel(S[1],S[97]) => Verwissel(1,0)  
k = S[ (S[1]+S[97])%256 ] => k = S[ (1 + 0) % 256 ]  
we outputten de waarde die op S[1] staat
```

Finaal zal deze *geoutputte* waarde k ge-xor'd worden met het huidige karakter van de plaintext.



Zo, dat viel nog mee he? Zoals al gezegd, een belangrijke motivatie van dit boek is aantonen dat je niet bang hoeft te zijn van wat er achter de schermen van de cyberwereld gebeurt. De hoeveelheid wiskunde die we bijvoorbeeld nodig hadden is beperkt gebleven tot onze trouwe modulo (%) -operator en meer niet. Wanneer we zo meteen een block ciphers gaan uitkleden zal je ook daar ontdekken dat je best in staat bent schijnbaar complexe technologieën te begrijpen. Hop naar de blockciphers dus!

Blockciphers

Block cipher modes

In de praktijk

DES tot op het bot

3DES

AES

Asymmetrische encryptie

TODO

Voorbeelden: RSA, Diffie-Hellman, Knapsack, ElGamal, DSA, ECC, etc.

Social Engineering

Sites to use

Network security

Algemeen

IPS en IDS

Honeypots

Dos

Wifi Security

Internet security

SQL Injection

S.Mime

SSL/TLS

Https

VPN

IPSEC

